Commonwealth Application Certification and Accreditation Policy

Effective Date:
January 06, 2025

Category:
Security

Scheduled Review:
January 2026

Supersedes:
ITP-SEC005

1. Authority

Executive Order 2016-06, Enterprise Information Technology Governance

2. Purpose

This Information Technology Policy (ITP) sets forth the policy and technical procedures for the Commonwealth Application Certification and Accreditation (CA)^2 Process. This process is a requirement of the *Electronic Transactions Act, Act No. 69 of 1999, 73 P.S. § 2260.101, et seq. (Act)* and *Management Directive (MD) 210.12, Electronic Commerce Initiatives and Security* to ensure compliance when using, sending, receiving, and storing electronic records and electronic signatures.

3. Scope

This policy applies to all offices, departments, boards, commissions, and councils under the Governor's jurisdiction and any other entity connecting to the Commonwealth Network (hereinafter referred to as "agencies").

4. Policy

For definitions found within this document, refer to the *IT Policy Glossary*.

This policy documents compliance with Chapter 5 of the *Electronic Transactions Act* relating to governmental agencies. It sets forth the rules for the acceptance and use of electronic transactions by governmental agencies and directs all executive agencies to comply with the standards established by the Office of Administration (OA).

In addition, *MD 210.12, Electronic Commerce Initiatives and Security* requires agencies to complete a security assessment prior to participating in or initiating an electronic transaction involving the use,

transmission, or storage of electronic records or electronic signatures. This assessment, known as the $(CA)^2$ process, is the subject of this ITP.

The $(CA)^2$ process is an assessment tool that measures a proposed E-Government initiative's compliance with OA, Office for Information Technology's (OA/IT) IT policies, procedures, and standards. The $(CA)^2$ process also identifies the inherent risks associated with an existing or proposed E-Government initiative. The $(CA)^2$ process is authorization to operate from OA/IT to agency owned websites.

Agencies must complete $(CA)^2$ assessments on:

- All web applications, application programming interfaces (APIs), mobile applications, or web application frameworks (hereinafter referred to as a "web application") that provide government services or process Commonwealth data.
- Web application frameworks that have not been vetted through the $(CA)^2$ process. Please review *Software Development Life Cycle Standard* for a list of approved web applications. Any derivation from approved web applications will require an IT policy exception against that standard.
- Hardware and virtual devices that host a web application, web services, databases, etc.
- Agencies shall refer to the *CA2 Applicability Decision Matrix Guideline* for the applicability of various scenarios depending on the type of data center, hosting environment, or computing service.

This policy shall not apply to Computing Services if the following conditions are met:

- The web application and its components are hosted by the vendor as outlined in the *IT Vendor Risk Management Policy* (also refer to *CA2 Applicability Decision Matrix Guideline*). This includes components that support the application such as web services, databases, etc.
- The terms and conditions of the contract place the responsibility for network and application security on the vendor. This includes host scanning, network vulnerability testing, web application vulnerability scanning, PCI scanning, etc.
- The terms and conditions of the contract include a confidential information clause, Non-Disclosure Agreement or similar language that protects the Commonwealth's data.

4.1 Accreditation

Agencies that have a web application shall submit a $(CA)^2$ request to EISO for an accreditation review. This review consists of policy compliance, coding scanning and web vulnerability assessments. Agencies shall follow the procedures outlined in CA2 Procedure when submitting a web application hosted within a data center or Commonwealth cloud instance (refer to *CA2 Applicability Decision Matrix Guideline*) for $(CA)^2$ accreditation. EISO may require an agency to prepare or resubmit a $(CA)^2$ request at any time.

Agencies who have a web application that receives a full accreditation shall ensure any changes to the security architecture are documented as outlined in section 4.5 (Accreditation Changes) of this policy to avoid any change in the status of their accreditation. In addition, agencies shall follow the procedures for reaccreditation as outlined in section 4.4 (Reaccreditation) to ensure continuous accreditation of their web application.

4.2 At Risk Applications & Conditional Accreditations

Any web application that goes through the accreditation process and has vulnerabilities that cannot be remediated prior to going into production will be deemed as an "at risk application". In addition, a non-accredited or conditionally approved web application will also be deemed as an "at risk application."

For the purpose of this policy, an "at risk application" is an application that:

- Is in production but has not undergone or completed the $(CA)^2$ process.
- Has initiated the $(CA)^2$ process but receives a conditional approval due to business constraints or vulnerabilities that cannot be remediated at the time the application needed to be put into production.

If deemed an "at risk application," the agency shall provide a risk analysis and mitigation plan, which includes probability and impact. The risk analysis and mitigation plan shall identify and provide analysis of the risks associated with the web application, planned mitigations and timeline, as well as identify how the agency plans to mitigate risk responses. This plan shall be attached to the $(CA)^2$ submission and the web application shall be resubmitted for review. The plan will be reviewed and a determination made if the web application will be granted a conditional accreditation valid for a period of time consistent on the agreed upon plan. Additional details on conditional accreditations and Risk Analysis and Mitigation Plans can be found within *CA2 Procedure*.

4.3 Conditional Accreditations

A conditional accreditation may only be granted for up to an 18-month grace period to allow the agency to remediate any vulnerability that was documented during the $(CA)^2$ process. The term of the grace period may vary but shall not exceed 18-months. Agencies shall ensure their web application is submitted for reaccreditation prior to the established grace period expiring.

If the agency does not submit for reaccreditation prior to its established grace period expiring, the web application will lose its conditional accreditation status and a new $(CA)^2$ request must be submitted.

No more than two (2) conditional accreditations will be granted per web application. Upgrades to the versioning of a web application will not reset the count of conditional accreditations. This is to ensure that vulnerabilities present on a Web application are being addressed by the agency in a timely manner to prevent security issues.

4.4 Reaccreditation

An accredited web application shall be submitted for reaccreditation every three (3) years to maintain its security accreditation. Any changes to an accredited web application's security architecture will void its previous accreditation status. To regain $(CA)^2$ accreditation, agencies shall submit a new or updated $(CA)^2$ request. Refer to *CA2 Procedure* for detailed requirements and procedures related to reaccreditations.

4.5 Accreditation Changes

Agencies shall ensure any changes to an accredited web application's security architecture or

software bill of materials (SBOM), as listed below, are documented in the $(CA)^2$ system as a new submission or a modification to a previous $(CA)^2$ request to prevent the web application from becoming non- accredited.

- New or upgraded hardware platform.
- New or upgraded operating system, middleware component, or application.
- Changes to system ports, protocols, or services.
- Changes in data types processed, stored, or transmitted by the system.
- Changes to how data is processed (refer to the *Data Classification Policy* to ensure data is properly identified, classified, and protected).
- Changes to cryptographic modules or services.
- Changes to security and/or privacy controls.

If a web application becomes non-accredited, the agency shall initiate a new $(CA)^2$ request for the accreditation of the web application. Failure to do so will violate Commonwealth policy.

4.6 Security Requirements

In addition to the security requirements established by OA/IT ITPs, there may also be agency-specific security requirements that are not captured by OA/IT policy, procedures, and standards, such as federal or state laws or regulations, executive orders, or management directives.

Since these requirements are agency or business-owner specific, it is the responsibility of the agencies to ensure:

- All required security controls mandated by law, agency policy, or business owner requirements (i.e., PCI, NIST, CJIS, IRS, etc.) are incorporated into the agency's web application security architecture.
- All appropriate security requirements are addressed in agency acquisitions of information systems and information system services.

4.7 Withdrawal from (CA)2

A web application that has started the $(CA)^2$ process but has not been updated within one year of the initial submission date shall be automatically withdrawn in the $(CA)^2$ system, and the Application Inventory will be updated. This is being done to remove any Web application that is not ready to begin the $(CA)^2$ process or has been cancelled and was not removed from the system.

Submitters can avoid having a web application removed from the $(CA)^2$ system by submitting an updated status report in the system's comments field or by contacting the $(CA)^2$ Administrator.

4.8 Roles within the (CA)2 Process

Role	Role Requirements	Role Responsibilities
Review Board	• (CA)^2 Administrator • (CA)^2 Subject Matter Experts	• Determine if submitted web application presents security threat to Commonwealth's IT infrastructure.
Administrator	• EISO Team Member	• Day-to-day administration of (CA)^2 system and process. • Addresses agency questions, comments, concerns, and issues. • Updates (CA)^2 system to address changes within OA/IT ITPs or security threats. • Entering and updating user accounts in (CA)^2 system. • Functions as coordinator of the Review Board and schedules meetings as needed.
Subject Matter Experts (SMEs)	Enterprise SMEs in the areas of: • Policy • Source code, or • Web Vulnerability (dynamic and host scans)	• Assist the EISO in the evaluation of (CA)^2 submissions. • Represent OA/IT in instances where clarification is needed, or agencies request technical assistance.
Point of Contact (POC)	• Agency application owner • Agency technical lead, or • Agency business owner	• Acts as the liaison between the agency, EISO, and the Review Board. • Ensure applicable web application is submitted through the (CA)^2 process every three (3) years to meet triennial reaccreditation requirements. • Contact the Administrator for (CA)^2 user updates/changes, requests for assistance with security scans, or to request a Review Board meeting.
Submitter	A Commonwealth employee from the submitting agency. • Role Preference: A project manager who understands security and Commonwealth policy.	• Submits and monitors (CA)^2 process for web application in accordance with policy procedures. • Updates web application information and resubmits through the (CA)^2 process if there are changes to the security architecture. • Provides business owners with updates on the status of applicable (CA)^2 submissions as they progress through the process.

Role	Role Requirements	Role Responsibilities
EISO	EISO Team Member(s)	• Conduct security assessments as requested by Agencies. • Update the $(CA)^2$ process in alignment with Commonwealth policies and current threat landscape. • Review source code scan reports to ensure applications do not have coding vulnerabilities. • Review host-based vulnerability scan reports to ensure the host is secure and most recent patches applied. • Review DAST scan reports to ensure there are no operational vulnerabilities.
Agency	• Submitter • POC • Information Security Officers • Agency application owner • Agency technical lead, or Agency business owner	• Appoint a primary and secondary POC. • Ensure completion of $(CA)^2$ for process agency web applications. • Ensure triennial completion of $(CA)^2$ required reaccreditation process for agency web applications. • Comply with policies, procedures, and standards in OA/IT ITPs, MDs, and applicable security frameworks (i.e., PCI, NIST, CJIS, IRS, etc.). • As requested, submit Risk Analysis and Mitigation Plans to EISO. • Follow up on any web application which receives conditional accreditation prior to expiration of grace period. • Capture agency or business owner specific security requirements not addressed in OA/IT ITPs. • Conduct Application and Host scanning and review reports to ensure vulnerabilities are not present and most recent patches are applied. If the agency has the proper tools and resources, scanning shall be conducted within the agency prior to EISO engagement. Scanning to include: • Static Application Security Testing (SAST) and Source Code Analysis (SCA) • Host-based Vulnerability Scans • Dynamic Application Scanning Technology (DAST)

5. Contact

Questions or comments may be directed via email to OA, IT Policy.

6. Exception from Policy

In the event an agency chooses to seek an exception from this policy, a request for a policy exception shall be submitted via the enterprise IT policy exception process. Refer to *IT Policy Governance Policy* for guidance.

7. Revision History

This chart contains a history of this publication's revisions. Redline documents outline the revisions and are available to Commonwealth users only during the drafting process.

Version	Date	Purpose of Revision
Original	01/06/2025	Base Document